

# Polaris PoVガイド

DAST編

2026/03/31

ブラック・ダック・ソフトウェア合同会社 パートナー担当



## PoVガイド DAST編

- [1 本資料について](#)
- [2 PoV作業の流れ](#)
- [3 構成確認](#)
  - [3.1 Polaris\(クラウド\)からアクセス可能な場合](#)
  - [3.2 テスト対象がプライベートネットワークにある場合](#)
- [4 DAST初期設定](#)
  - [4.1 アプリケーションとプロジェクトの作成](#)
  - [4.2 Applicationの作成](#)
  - [4.3 DAST Projectと Profile の作成](#)
    - [4.3.1 Authentication](#)
- [5 解析](#)
  - [5.1 SecureTunnel](#)
- [6 結果確認](#)
  - [6.1 代表的な解析方法の結果](#)
- [7 Appendix](#)
  - [7.1 Web API のプロファイル作成](#)
  - [7.2 Scan Settings](#)
  - [7.3 CLI からの DAST テスト起動](#)
  - [7.4 Chrome Recording ファイルの作成例](#)

## 1 本資料について

本資料は、Polaris の PoC 手順のうち、DAST 機能 (fAST Dynamic) 固有の手順について記載するものです。PoC で共通する注意事項や、SAST/SCA 機能と共通する要素については、記載してありません。Polaris PoCガイド(メイン資料)を先に参照してください。

ドキュメント:[Test web applications and APIs with Polaris fAST Dynamic](#) も参考にしてください。

## 2 PoV作業の流れ

1. アカウント作成(SAST/SCAと共通)
2. DAST初期設定
3. DAST解析
4. 結果の閲覧(SAST/SCAと一部共通)

### 3 構成確認

テスト対象のアプリケーションが、Polaris からアクセス可能かどうかで構成が変化します。

#### 3.1 Polaris(クラウド)からアクセス可能な場合

Polaris はテスト対象のアプリケーションに直接アクセスします。

PolarisのIPアドレスは以下のレンジです (参考: [Polaris IP ranges](#))

- 192.231.134.0/24

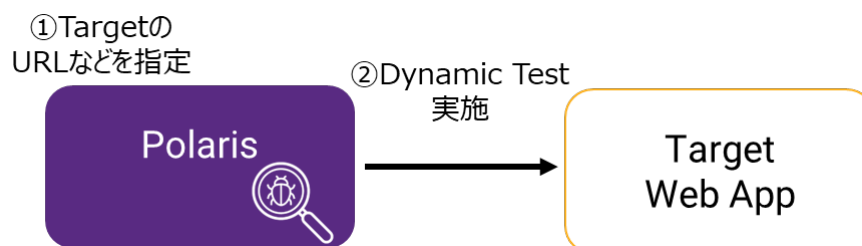


図:外部からのDASTテスト

#### 3.2 テスト対象がプライベートネットワークにある場合

テスト対象がプライベートネットワークにある場合、テスト実施中は Secure Tunnel の起動が必要です。※Secure Tunnel (Teleport) の動作環境は **Mac**または**Linuxのみ** サポートします。

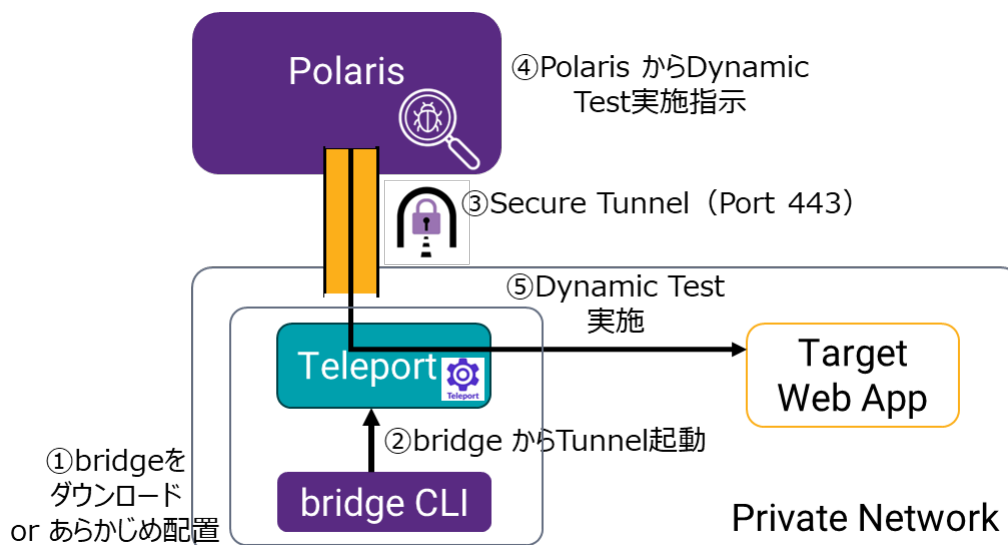


図:Private Network

## 4 DAST初期設定

### 4.1 アプリケーションとプロジェクトの作成

Application と Project は解析結果を管理する単位です。解析前にそれぞれを作成します。

### 4.2 Applicationの作成

1. Applicationの作成Portfolioの「+Create」>「New Application」をクリック
2. Application Detailsを設定
  - Application Name: 任意の名前(検証対象のソフトウェア名など)
  - Subscriptions:
    - 「SAST/SCA/DAST Subscription」:それぞれPoC用のSubscriptionを選択
    - DASTの解析を行うためには、DAST Subscription を割り当ててください。

標準的なPoCでは Application・DAST Project は1つのみ作成可能です。Application の作成時点で Subscription を消費するため、作成済みApplicationを削除しないでください。追加申請が必要になります。

### 4.3 DAST Project と Profile の作成

1. SAST/SCA と同様に、Application の「+Create」> 「New Project」をクリック
2. Project 作成画面で、以下を入力
  - Project Type:DAST
  - Project Name:任意の名前
  - Entry Point URL:テストターゲットのURL
    - Internal の場合は「~ in a private network」にチェックを入れた上で、Secure Tunnelから見た内部のアドレスを入力
  - Target Type: Web Application または API を選択
3. Project の作成画面でDAST Profile を設定
  - Profile Name:任意の名前
  - Perform Active Attacks:チェックを入れるとより侵入的なテストを有効にします
    - 本番環境での使用は意図されていません
  - Allowed Hosts : 一時的にEntry Pointと違うドメインに遷移する場合にURLを入力
    - 例)
      - Entry Point URL: `https://example.com/`
      - Allowed Hosts : `https://securelogin.example.com/`
      - Authentication Login Type: [Authentication](#) を参照
4. 【スキップ可能】設定入力が終わったら、「Test Connection」を実施
  1. 【Private Networkのみ実施】 Secure Tunnel を起動 詳細:
  2. 「Test Connection」をクリック してテスト接続
    - Connection successful が表示されたら テスト接続は成功です。
    - 失敗した場合は、失敗時のログやスクリーンショットを表示するリンクが表示されます。
5. 「Save」で Project と Profile を保存

#### Note

保存後にDAST Profile を編集する場合は、DAST Project 内の「DAST Profiles」タブから編集します

#### 4.3.1 Authentication

Polarisが対象のアプリケーションにログインしてテストするための認証情報を Profileの Authenticationの項目で設定します。詳細:[Create DAST projects for web applications and APIs](#)

2026/3/31現在、Login Type として以下が用意されています。

- none …ログイン不要
- ai …AIによるスマートなログイン(推奨)
- simple…ユーザー名とパスワードなどを指定のテキストボックスに入力するシンプルな方式
- SAML : ログインにSAMLが選択されている場合に選択。基本はSimpleと同様のインプットが必要。
- selenium : Selenium で記録した手順(.side ファイル)でログイン
- chrome-recording : Chrome Recording で記録した手順(.jsonファイル)でログイン
- header … ヘッダーによる認証
- basicAuth … Basic認証

##### 4.3.1.1 ai

URL・ユーザー名・パスワード を入力すると、Polaris の AI アシストにより画面を自動認識し最適なログインを行います。

ワンタイムパスワードを使う場合はOTPのメールアドレスとシークレットを追加で入力することも可能です。

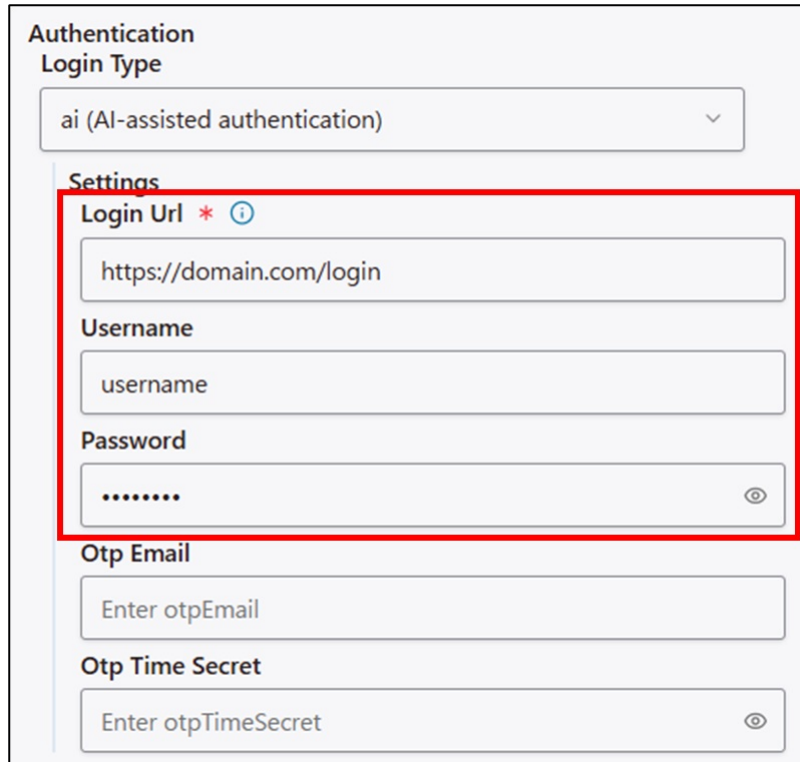


図:DAST Profile設定 AI

#### 4.3.1.2 simple

フィールドの「どこ」に「何」を入力するかの手順(Steps)を細かく設定して、ログイン処理をPolarisに指定します

- Steps…手順。画面が複数にわたる場合は2つ以上を設定。
- Inputs…入力する値を設定
  - Identifier Type: Name, id, xpath, CSS から選択し、フィールドを探すキーの種類を指定
  - Identifier: Identifier Typeに応じた識別子を入力
  - Value Type: text, totp から指定(基本はtext)
  - Value: 入力する値

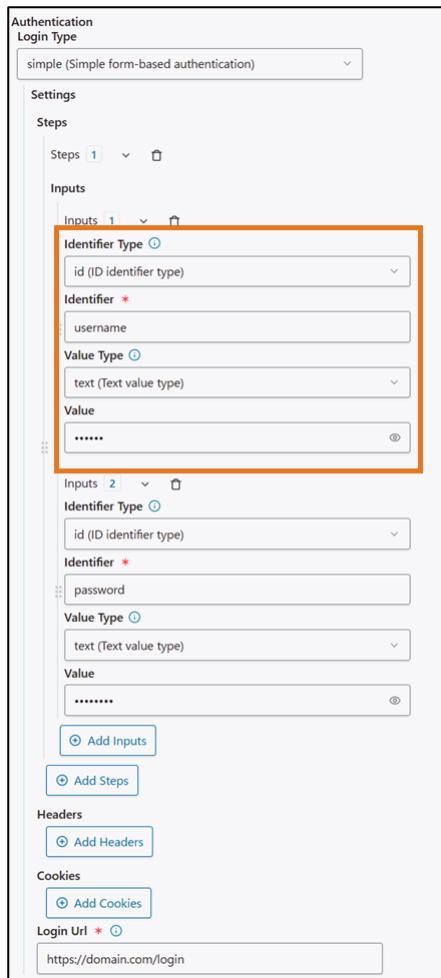


図:DAST Profile設定 simple

#### 4.3.1.3 chrome-recording

Chrome の Recording 機能でレコーディングを用いてログインします。Chrome RecordingからエクスポートしたJSONファイルの中身をコピー&ペーストして、Polarisにログイン手順を指示します。

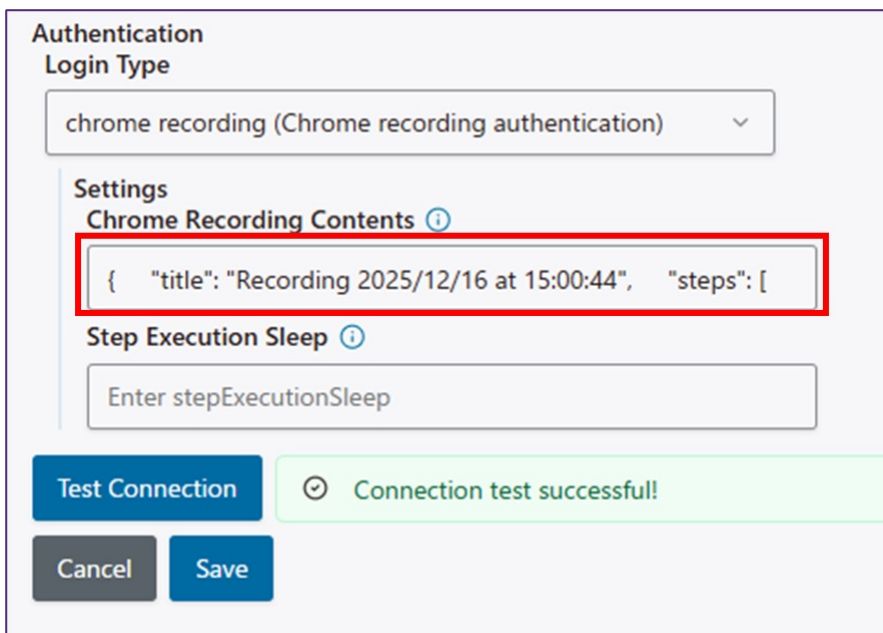




図:DAST Profile設定

## 5 解析

Project の右側のメニューから「New Test」をクリックして DASTのTestを開始します。Private Network のテスト対象の場合は、起動前に [SecureTunnel](#) を実施してください。Polaris から 対象のWebアプリケーションへのテストが開始されます。

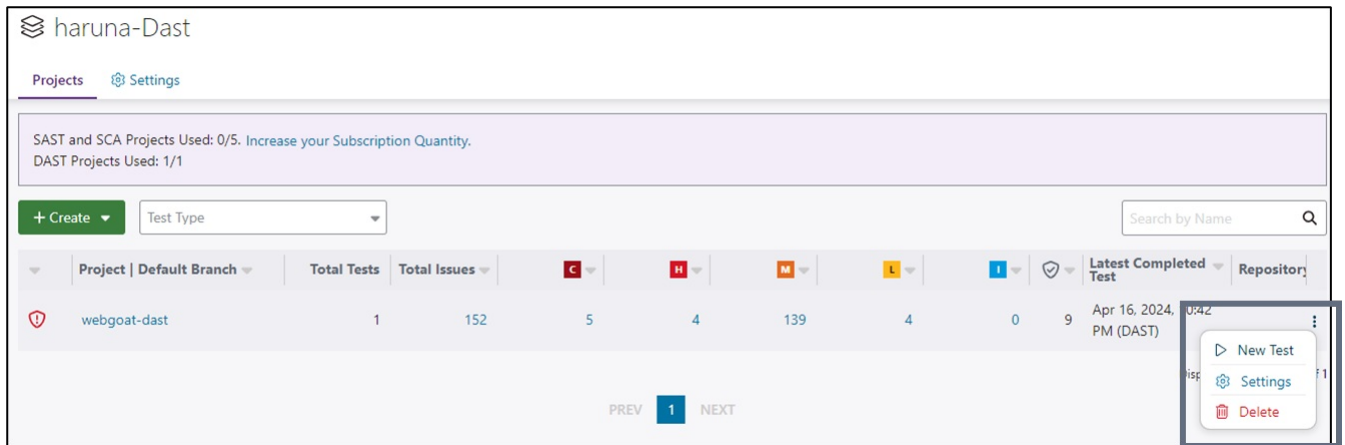


図:DAST Test開始

### 5.1 SecureTunnel

Private Network 内のサイトの DAST テストをする場合は、下記手順で Secure Tunnel を起動した状態にしてください。

1. Bridge CLIをダウンロード
2. 以下のコマンドで、Bridge CLIを用いて Tunnel を起動
  - Error 表示がなく、「The new service has started successfully.」のメッセージが表示されることを確認

コマンド:Secure Tunnelの起動

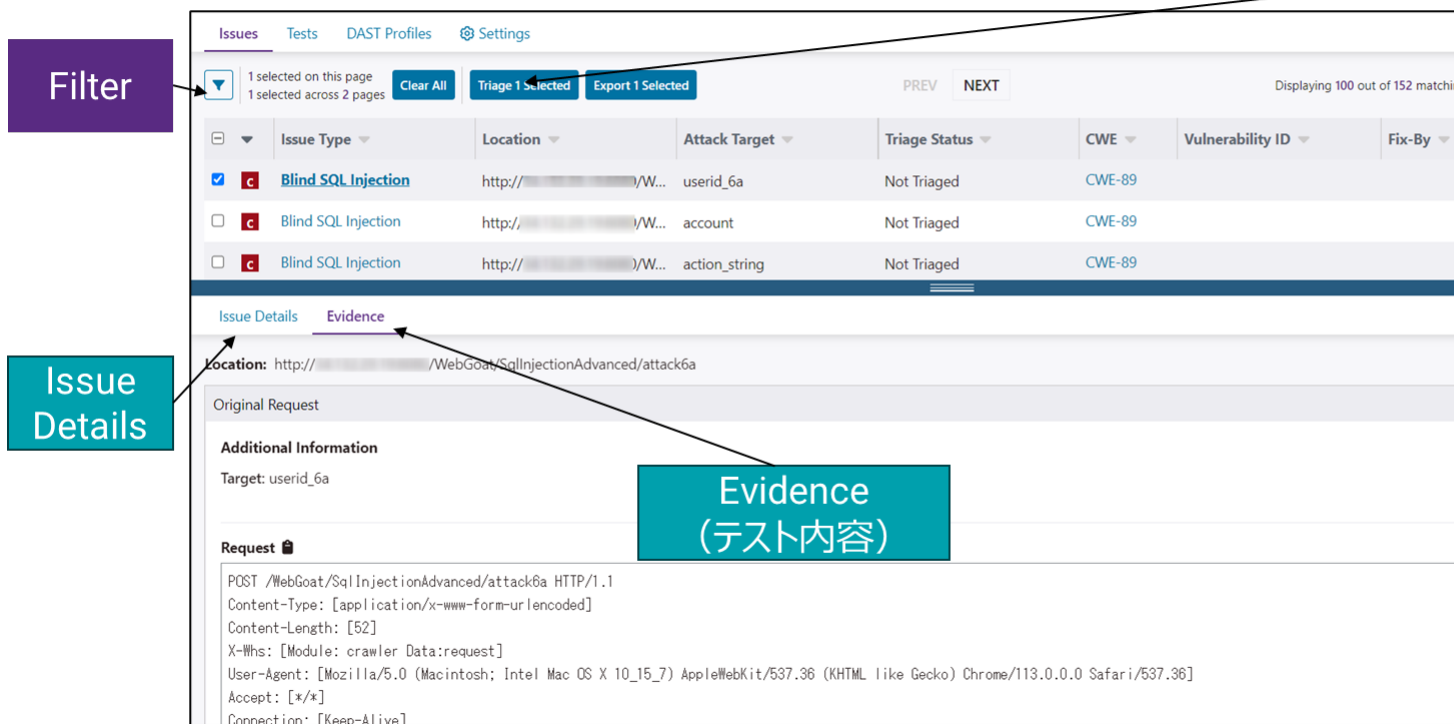
```
export BRIDGE_POLARIS_ACCESSTOKEN=<POLARIS_ACCESSTOKEN>
bridge-cli --stage polaris-secure-tunnel \
  polaris.application.name=アプリケーション名 \
  polaris.project.name=プロジェクト名 \
  polaris.serverUrl="https://poc.polaris.blackduck.com"
```

詳細:[Connect to an internal DAST target from the Bridge CLI](#)

## 6 結果確認

### 6.1 代表的な解析方法の結果

SAST/SCA と同様に Project の Issues タブから結果を確認します。



The screenshot displays the Black Duck web interface for viewing issues. A purple box labeled "Filter" points to the filter icon in the top left of the issues table. A teal box labeled "Issue Details" points to the "Issue Details" tab in the expanded issue view. Another teal box labeled "Evidence (テスト内容)" points to the "Evidence" tab in the same view.

**Issues Table:**

| Issue Type                                                       | Location        | Attack Target | Triage Status | CWE    | Vulnerability ID | Fix-By |
|------------------------------------------------------------------|-----------------|---------------|---------------|--------|------------------|--------|
| <input checked="" type="checkbox"/> <b>c</b> Blind SQL Injection | http://.../W... | userid_6a     | Not Triageed  | CWE-89 |                  |        |
| <input type="checkbox"/> <b>c</b> Blind SQL Injection            | http://.../W... | account       | Not Triageed  | CWE-89 |                  |        |
| <input type="checkbox"/> <b>c</b> Blind SQL Injection            | http://.../W... | action_string | Not Triageed  | CWE-89 |                  |        |

**Issue Details View:**

- Location:** http://.../WebGoat/SqlInjectionAdvanced/attack6a
- Original Request:** [View]
- Additional Information:**
  - Target: userid\_6a
- Request:**

```
POST /WebGoat/SqlInjectionAdvanced/attack6a HTTP/1.1
Content-Type: [application/x-www-form-urlencoded]
Content-Length: [52]
X-Whs: [Module: crawler Data:request]
User-Agent: [Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML like Gecko) Chrome/113.0.0.0 Safari/537.36]
Accept: [*/]
Connection: [Keep-Alive]
```

図:Issuesの画面

「Info」(青い i アイコン)レベルのIssues では、DAST テストのクローリング結果などのテスト実施レポートを確認することが可能です。

テスト実施後はテストのクローリング結果を確認してください。

Issues
Tests
DAST Profiles
Settings

▼

☐
▼

Issue Type
▼

☐
▼

Location
▼

☐
▼

Attack Target
▼

☐
▼

Tool Type
▼

☐
▼

Triage Status
▼

☐
▼

CWE
▼

☐
▼

Fix-By
▼

Displaying 11 out of 11 issues

|                          |          |                     |                             |  |      |             |         |  |
|--------------------------|----------|---------------------|-----------------------------|--|------|-------------|---------|--|
| <input type="checkbox"/> | <b>L</b> | Fingerprinting      | http://localhost:5000/login |  | DAST | Not Triaged | CWE-497 |  |
| <input type="checkbox"/> | <b>I</b> | <b>Crawl Report</b> | http://localhost:5000/      |  | DAST | Not Triaged |         |  |

Issue Details
Evidence

Location: http://localhost:5000/

Issue Details

**First Detected in This Branch:**  
Aug 28, 2025, 2:05 PM

**Fix-By:**  
No Date

**Issue Type:**  
Crawl Report

**Description:**  
Found URLs:  
http://localhost:5000/  
http://localhost:5000/login  
http://localhost:5000/register

**Tool & Tool Type:**

**Scan Date and Time:**  
Aug 28, 2025, 2:05 PM

**Vulnerability: Overall Score**  
-1

**Severity:**  
**I** Informational

**Remediation:**  
None

図: クローリング結果

## 7 Appendix

### 7.1 Web API のプロファイル作成

Polaris では Web API のDAST テストを実施可能です。Web アプリケーション用とは別にDAST Project が必要になります。両方実施する場合は 2 つの Project が必要になります。実施には、API の定義情報が必要です。

DAST Profile の設定項目の中で、API固有の設定は以下となります。

- Authentication: none または headerを選択 - Headers の場合、テスト対象の認証のために必要なキーなどを入力
- API Specification Type: APIの定義ファイルをアップロードまたはURLを入力
  - サポートする形式
    - OpenAPI / Swagger Specification (.yaml, .yml, .json)
    - Postman Collection (.json)
    - HTTP Archive file (.har)
    - GraphQL SDL (.sdl)
    - GraphQL Introspection URL

### 7.2 Scan Settings

DAST Profile 設定画面の「Scan Settings」タブでは、より細かい DAST Profile 設定を提供しています。

※PoV では担当SEと相談しながら、必要に応じての利用を推奨します

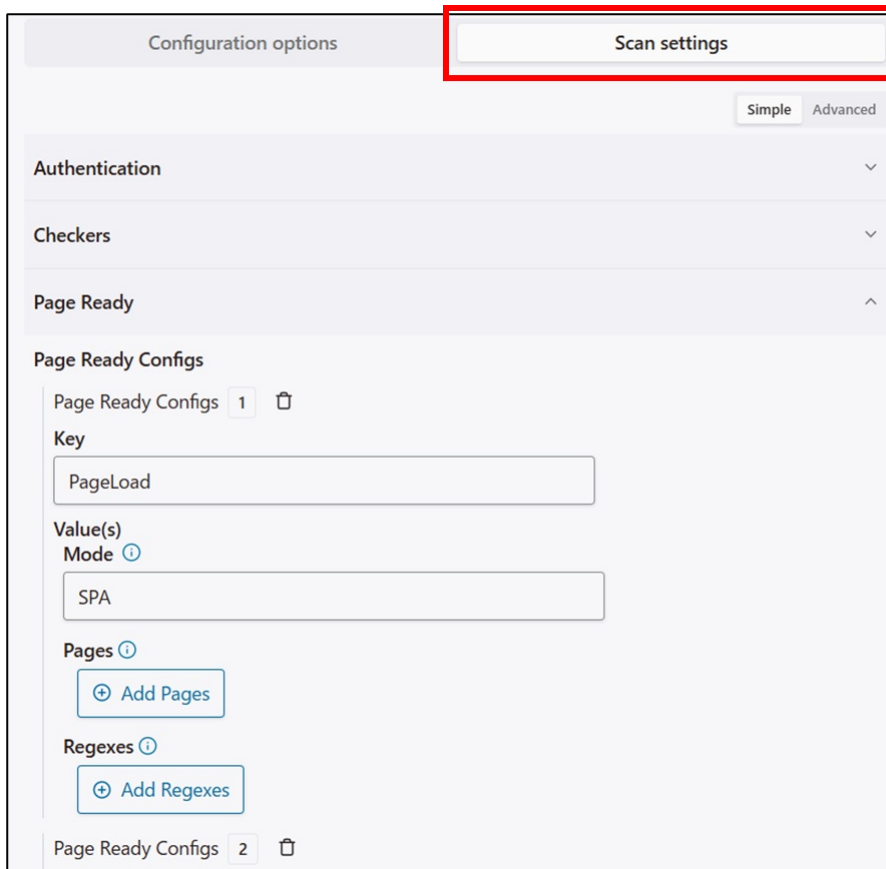


図:DAST Profileの画面

Scan Settings は JSON形式で、「Download Scan Settings」から保存、「Load Scan Settings File」から再読み込みをすることが可能です。

詳細ドキュメント

- [DAST scan settings](#)
- [Configure JSON scan settings and authentication profiles](#)

### 7.3 CLI からの DAST テスト起動

Bridge CLI を使用して、CLI からDAST テストを起動することも可能です。GUIからの起動の方がエラーログが見やすいため、初期設定が終わった後の継続的なテストにご利用ください

い。CLI から起動すると、Internal のテスト対象をテストする場合、Secure Tunnel も自動的に実行します。

Polaris オプション例: CLIからのDAST起動

```
{
  "data": {
    "polaris": {
      "application": { "name": "アプリケーション名" },
      "project": { "name": "プロジェクト名" },
      "assessment": {
        "types": ["DAST"]
      },
      "serverUrl": "https://poc.polaris.blackduck.com/"
    }
  }
}
```

コマンド例:

```
bridge-cli --stage polaris --input input.json
```

## 7.4 Chrome Recording ファイルの作成例

2025/12/16 時点の参考手順

1. 起動: Chrome の開発者ツールの「Recorder」タブを開く
2. レコーディング: 「Create recording」をクリック
  - 「RECORDING NAME」に任意の名前を入力
  - 「Start recording」ボタンをクリック
  - (レコーディングが始まり、操作手順が記録される)
  - 「End Recording」をクリック
3. 編集と動作確認
  - レコーディング後の各行(Step)をクリックして操作内容を確認。ログイン処理に不要なステップがあれば削除。
  - 「Replay」ボタンから、ログイン処理ができるか確認。
4. エクスポート
  - Export(下矢印アイコン) からJSON形式でエクスポート

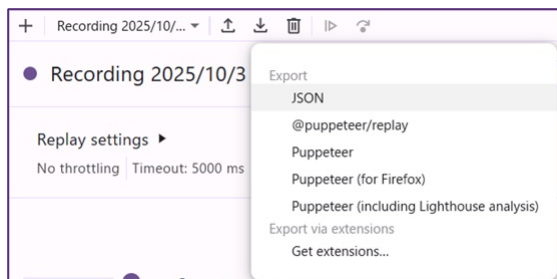


図: Chrome Recording



## 本資料のご使用について

- 本資料の内容は予告なく変更することがありますのでご了承ください。
- 本資料の作成者および提供者は、本資料に関していかなる種類の保証を負うものではありません。また本資料の作成者および提供者は、本資料の使用における直接的・間接的また結果的に生じたいかなる損害についても責任を負うものではありません。
- 本資料の内容は、本資料の作成者および権利所有者に帰属します。使用者はこれらの権利を尊重し、無断での利用や転載を行わないようにお願いします。